

NMAP 포트스캔 보고서

스캔 대상 bWAPP(192.168.xxx.xxx)

Nmap 포트 스캔 정보

```
(root@kali) - [/home/kali]
# sudo nmap -sV -oX nmap_result.xml 192.168.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 03:00 -0400
Nmap scan report for 192.168.
Host is up (0.019s latency).
Not shown: 983 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.1
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_fastcgi/2.4
.6 PHP/5.2.4-2ubuntu5 with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: ITSECGAMES)
443/tcp   open  ssl/http     Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_fastcgi/2.4
.6 PHP/5.2.4-2ubuntu5 with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: ITSECGAMES)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  shell?
666/tcp   open  doom?
3306/tcp  open  mysql        MySQL 5.0.96-0ubuntu3
5901/tcp  open  vnc           VNC (protocol 3.8)
6001/tcp  open  X11           (access denied)
8080/tcp  open  http         nginx 1.4.0
8443/tcp  open  ssl/http     nginx 1.4.0
9080/tcp  open  http         lighttpd 1.4.19
1 service unrecognized despite returning data. If you know the service/version
```

결과물을 xml 파일로 저장하기 위해

```
sudo nmap -sV -oX nmap_result.xml 192.168.xxx.xxx
```

해당 코드를 사용하여 nmap_result.xml 파일 생성

XML 파일 (XML 파일을 폴더에 첨부했으니 참고바람.)

cpe:/a:proftpd:proftpd:1.3.1

cpe:/a:openbsd:openssh:4.7p1

cpe:/o:linux:linux_kernel

cpe:/a:postfix:postfix

cpe:/a:apache:http_server:2.2.8

cpe:/a:samba:samba

cpe:/a:apache:http_server:2.2.8

cpe:/a:samba:samba

cpe:/a:netkit:netkitcpe:/o:linux:linux_kernel

cpe:/a:mysql:mysql:5.0.96-0ubuntu3

cpe:/a:igor_sysoev:nginx:1.4.0

cpe:/a:igor_sysoev:nginx:1.4.0

cpe:/a:lighttpd:lighttpd:1.4.19

서비스별 보안 위험 분석 및 보완 방법

Nmap 서비스 및 버전 탐지 결과를 분석한 결과, 대상 서버에서는 FTP, SSH, SMTP, HTTP/HTTPS, Samba, MySQL, VNC, Proxy 및 여러 Web 서비스가 확인되었다.

FTP – 21/tcp

탐지 결과

- Port: 21/tcp
- Service: FTP
- Version: ProFTPD 1.3.1

보안 위험

FTP는 기본적으로 평문 통신을 사용하는 프로토콜이므로 인증 정보와 파일 전송 내용이 네트워크에서 노출될 가능성이 있다.

또한 탐지된 ProFTPD 버전이 오래된 버전이므로 알려진 보안 취약점의 영향을 받을 가능성을 확인해야 한다.

보완 방법

- FTP 사용이 필요하지 않다면 서비스 중지
- 방화벽에서 21/tcp 외부 접근 제한
- 필요한 경우 SFTP 또는 FTPS 사용
- ProFTPD를 지원되는 최신 버전으로 업데이트
- 익명 FTP 접속 비활성화
- 강력한 인증 정책 적용

SSH – 22/tcp

탐지 결과

- Port: 22/tcp
- Service: SSH
- Version: OpenSSH 4.7p1

보안 위험

SSH는 원격 서버 관리에 필요한 서비스이지만, 외부에 직접 노출될 경우 무차별 대입 공격이나 취약한 계정 정보를 이용한 공격의 대상이 될 수 있다.

또한 OpenSSH 4.7p1은 매우 오래된 버전이므로 최신 보안 업데이트가 적용된 버전인지 확인할 필요가 있다.

보완 방법

- SSH를 최신 지원 버전으로 업데이트
- 외부에서 반드시 접근해야 하는 IP만 허용
- 방화벽 및 Security Group을 이용한 접근 제어
- root 직접 로그인 제한
- 비밀번호 인증 대신 SSH Key 인증 사용
- Fail2ban 등을 이용한 반복적인 로그인 시도 차단
- 불필요한 SSH 외부 노출 제한

SMTP – 25/tcp

탐지 결과

- Port: 25/tcp
- Service: SMTP
- Version: Postfix

보안 위험

SMTP 서버가 외부에 노출된 경우 잘못된 설정에 따라 Open Relay 문제나 스팸 메일 발송에 악용될 가능성이 있다.

보완 방법

- 외부에서 SMTP 서비스를 제공할 필요가 없다면 25/tcp 차단

- Open Relay 여부 점검
- 인증된 사용자만 메일 발송 가능하도록 설정
- Postfix 최신 보안 업데이트 적용
- 메일 서버 접근 제어 정책 적용

HTTP – 80/tcp

탐지 결과

- Port: 80/tcp
- Service: HTTP
- Version: Apache HTTP Server 2.2.8

보안 위험

HTTP는 암호화되지 않은 통신이므로 로그인 정보와 같은 민감한 데이터가 평문으로 전달될 가능성이 있다.

또한 Apache 2.2.8은 매우 오래된 버전이므로 알려진 보안 취약점과 지원 종료 여부를 확인해야 한다.

보완 방법

- Apache 최신 지원 버전으로 업데이트
- HTTPS 사용
- HTTP 요청을 HTTPS로 리다이렉트
- 민감한 정보는 평문 HTTP로 전송하지 않도록 구성
- 불필요한 디렉터리 및 파일 접근 제한
- 웹 서버 보안 설정 및 보안 헤더 적용

HTTPS – 443/tcp

탐지 결과

- Port: 443/tcp
- Service: HTTPS
- Version: Apache HTTP Server 2.2.8

보안 위험

HTTPS가 활성화되어 있어도 웹 서버 자체의 버전이 오래되었거나 TLS 설정이 취약하면 보안 문제가 발생할 수 있다.

따라서 HTTPS 사용 여부만으로 웹 서비스가 안전하다고 판단해서는 안 된다.

보완 방법

- Apache 최신 버전 사용
- 최신 TLS 버전 사용
- 취약한 SSL/TLS 프로토콜 및 Cipher 비활성화
- 유효한 인증서 사용
- HTTP → HTTPS 강제 전환
- 웹 애플리케이션의 인증 및 세션 보안 점검

NetBIOS / SMB – 139, 445/tcp

탐지 결과

- Port: 139/tcp
- Port: 445/tcp
- Service: Samba / Microsoft-DS

보안 위험

SMB/Samba 서비스가 외부에 노출되면 공유 폴더 및 인증 서비스를 대상으로 한 공격 가능성이 증가한다.

특히 불필요한 SMB 서비스가 인터넷 또는 신뢰하지 않는 네트워크에 노출되는 것은 보안상 위험할 수 있다.

보완 방법

- 외부에서 SMB 접근이 필요하지 않다면 139/445 차단
- Samba 최신 보안 업데이트 적용

- 공유 폴더 접근 권한 최소화
- Guest/익명 접근 제한
- SMBv1과 같이 오래된 프로토콜 사용 여부 점검
- 내부 네트워크에서 필요한 호스트만 접근 허용

MySQL – 3306/tcp

탐지 결과

- Port: 3306/tcp
- Service: MySQL
- Version: MySQL 5.0.96-0ubuntu3

보안 위험

데이터베이스 포트가 외부에 직접 노출되면 계정 공격이나 데이터베이스 취약점 공격의 대상이 될 수 있다.

특히 MySQL 5.0 계열은 매우 오래된 버전이므로 최신 지원 버전으로의 업그레이드 필요성을 검토해야 한다.

보완 방법

- 외부에서 3306/tcp 직접 접근 차단
- 애플리케이션 서버에서만 DB 접근 허용
- MySQL 최신 지원 버전으로 업데이트
- 강력한 DB 계정 비밀번호 사용
- root 원격 로그인 제한
- 최소 권한의 DB 계정 사용
- 방화벽을 통한 접근 제어

권장 구조

Internet



Web / Application Server



MySQL

사용자가 MySQL에 직접 접근하는 구조보다는 Application 서버를 통해서만 DB에 접근하도록 제한하는 것이 바람직하다.

VNC – 5901/tcp

탐지 결과

- Port: 5901/tcp
- Service: VNC

보안 위험

VNC는 원격 화면 접속을 제공하는 서비스이므로 외부에 노출될 경우 인증 공격이나 원격 접속 공격의 대상이 될 수 있다.

보완 방법

- 외부에서 직접 VNC 접근 차단
- VPN 또는 SSH Tunnel을 통한 제한적인 접근
- 강력한 인증 사용
- VNC 최신 버전 사용
- 관리 목적이 끝난 경우 서비스 중지

HTTP Proxy – 8080/tcp

탐지 결과

- Port: 8080/tcp
- Service: HTTP
- Version: nginx 1.4.0

보안 위험

8080 포트에서 Proxy 또는 Web 서비스가 동작하는 경우 외부 사용자가 의도하지 않은 방

식으로 접근할 수 있는지 확인해야 한다.

Proxy 서비스가 잘못 설정된 경우 다른 네트워크로의 우회 접근이나 Open Proxy 문제로 이어질 가능성이 있다.

보완 방법

- 8080 서비스의 실제 용도 확인
- 불필요하면 서비스 중지
- 외부 접근 차단
- Proxy 기능이 필요한 경우 허용된 사용자와 IP만 접근 가능하도록 설정
- nginx 최신 지원 버전으로 업데이트

HTTPS-alt - 8443/tcp

탐지 결과

- Port: 8443/tcp
- Service: HTTPS
- Version: nginx 1.4.0

보안 위험

8443 포트에서 별도의 Web 서비스가 동작하는 것으로 확인되므로 해당 서비스의 관리 인터페이스나 개발용 애플리케이션이 외부에 노출되어 있는지 확인할 필요가 있다.

보완 방법

- 해당 포트의 서비스 목적 확인
- 관리자 페이지인 경우 외부 접근 제한
- 인증 및 권한 검증
- nginx 최신 버전 사용
- 불필요한 포트는 방화벽에서 차단

HTTP - 9080/tcp

탐지 결과

- Port: 9080/tcp
- Service: HTTP
- Version: lighttpd 1.4.19

보안 위험

9080 포트의 별도 Web 서비스가 외부에 노출되어 있으므로 해당 서비스의 필요성과 접근 범위를 확인해야 한다.

또한 탐지된 lighttpd 버전이 오래된 버전이므로 보안 업데이트 여부를 확인할 필요가 있다.

보완 방법

- 서비스의 실제 사용 목적 확인
- 불필요한 경우 서비스 중지
- 외부 접근 제한
- 최신 지원 버전으로 업데이트
- 관리자 기능이 존재하는 경우 인증 및 접근 제어 강화

종합 위험 분석

이번 Nmap 스캔에서 확인된 서비스 중 우선적으로 점검할 항목은 다음과 같다.

우선순위	대상	주요 이유
높음	MySQL 3306	데이터베이스 직접 노출 가능성
높음	VNC 5901	원격 관리 서비스 외부 노출
높음	FTP 21	평문 통신 및 오래된 버전
높음	SMB 139/445	파일 공유 서비스 외부 노출 위험
높음	HTTP 80	평문 HTTP 및 오래된 Apache
중간	SSH 22	원격 관리 서비스 노출
중간	SMTP 25	Open Relay 및 메일 서버 설정 점검
중간	8080/8443	별도 Web/Proxy 서비스 노출
중간	9080	별도 Web 서비스 노출

단, 위 우선순위는 Nmap의 포트 및 버전 탐지 결과를 바탕으로 한 1차적인 점검 우선순위이며, 실제 취약점의 존재 여부와 위험도는 별도의 취약점 진단 및 설정 검토를 통해 확인해야 할 필요가 있다.

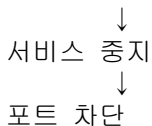
보완 방안

이번 스캔 결과를 바탕으로 다음과 같은 보안 조치를 권고한다.

-불필요한 서비스 제거

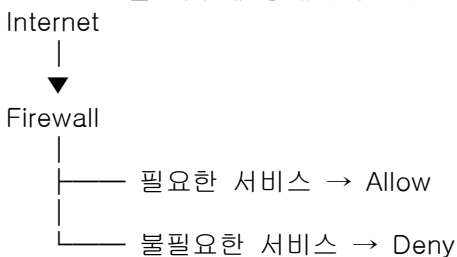
사용하지 않는 서비스는 실행하지 않는 것이 가장 기본적인 보안 조치이다.

사용하지 않는 서비스



-네트워크 접근 제어

모든 포트를 외부에 공개하기보다는 서비스별로 필요한 출발지 IP와 포트만 허용한다.



-최신 보안 패치 적용

스캔 결과에서 확인된 서비스 버전이 오래된 경우 해당 버전의 지원 상태와 알려진 취약점 존재 여부를 확인하고 최신 지원 버전으로 업데이트한다.

-최소 권한 적용

서비스와 계정에 필요한 최소한의 권한만 부여한다.

특히 데이터베이스나 파일 공유 서비스는 관리자 권한을 일반 사용자에게 부여하지 않도록 한다.

-민감한 서비스의 외부 직접 접근 제한

MySQL, VNC, SMB와 같은 내부 서비스는 인터넷에서 직접 접근할 필요가 없는 경우 외부 접근을 차단하고 내부 네트워크 또는 VPN 등을 통해 제한적으로 접근하도록 구성한다.

최종 의견

이번 Nmap 스캔을 통해 대상 서버에서 다수의 네트워크 서비스가 외부에 노출되어 있음을 확인하였다.

특히 FTP, SMB, MySQL, VNC와 같은 서비스는 서비스의 특성상 외부에 직접 노출할 필요가 있는지 우선적으로 검토할 필요가 있다.

또한 Apache, OpenSSH, MySQL, nginx, lighttpd 등에서 확인된 버전은 상당히 오래된 버전이므로 실제 운영 환경이라면 해당 버전의 지원 종료 여부와 알려진 보안 취약점을 확인하고 최신 지원 버전으로 업데이트하는 것이 필요하다.

다만 이번 결과는 Nmap을 이용한 포트 및 서비스/버전 탐지 결과이므로, 특정 서비스에 실제 취약점이 존재한다고 단정할 수는 없다. 따라서 본 결과를 1차적인 보안 점검 자료로 활용하고, 이후 취약점 진단 도구 및 수동 점검을 통해 실제 취약점 여부를 추가적으로 검증하는 것이 바람직하다.

최종적으로 불필요한 서비스 제거, 방화벽을 이용한 접근 제어, 최신 보안 패치 적용, 최소 권한 설정을 통해 서버의 공격 표면을 최소화할 것을 권고한다.